IS02 — Access Control Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

1) [Parent Company] IT – Corporate Information Security Policy

2) BS ISO/IEC 27001:2022 "Information security, cybersecurity and privacy protection - Information management systems - Requirements" + Annexes, ISO

3) BS ISO/IEC 27000:2020 "Information technology - Security techniques -Information security management systems - Overview and vocabulary", ISO

4) IS01 - [Company] Information Security Policy

Definitions and Terms

Definitions and terms are taken mainly from BS ISO/IEC 27000:2020 and related standards and policies.

Term / Acronym	Definition
IdP (Identity Provider)	Service used to manage digital identities and authentication, e.g., Entra ID, [Parent Company] IT IdP.
Cloud Services	SaaS (Software-as-a-Service) applications such as Power BI, GitHub, Azure, etc.
Zero Trust	Security model that assumes no implicit trust, requiring continuous verification of identities, devices, and access.

Term / Acronym	Definition
Least Privilege	Principle of granting users the minimal level of access needed to perform their tasks.
JIT/JEA (Just-in-Time / Just-Enough-Access)	Temporary and minimal access rights granted only when and as long as needed.
SIEM (Security Information and Event Management)	A system that provides real-time monitoring and analysis of security events.
RBAC (Role-Based Access Control)	Access control mechanism that assigns permissions based on user roles within the organization.
Entra PIM (Privileged Identity Management)	Microsoft Entra feature for managing, monitoring, and controlling privileged accounts and access.
OIDC (OpenID Connect)	Authentication protocol built on OAuth2, commonly used for modern single sign-on (SSO).
SAMLv2 (Security Assertion Markup Language 2.0)	XML-based protocol used for exchanging authentication and authorization data between parties.
OAuth2	Authorization framework that enables applications to obtain limited access to user accounts on an HTTP service.
Managed Identity	Azure mechanism for providing an automatically managed identity to access Azure services securely.
Digital Identity	Unique representation of a person, device, or service in an identity management system.
Device Identity	Unique identifier assigned to a specific device (e.g., sensor, gateway).
Service Principal	Identity for an application or service to access resources in Azure.
Delegation/Impersonation	Acting on behalf of another identity; explicitly prohibited in this policy.
B2C IdP (Business-to-Consumer Identity Provider)	Identity provider service for customer authentication.
Blast Radius	The potential impact or damage that could result from a security breach.

Overview

This document describes the policy and commitments that provide access control for data and assets in the [Company] IIoT Platform.

Purpose

The purpose of this policy is to set out the access controls that apply to the [Company] IIoT Platform, operated by [Company] as part of the [Parent Company] organization, to protect the confidentiality, integrity and availability of the data stored and processed by [Company] assets.

Scope

All employees, developers, contractors, customers and third parties of the [Company] platform.

Policy

Introduction

The [Company] IIoT Platform consists of three conceptual layers: the sensor layer, the gateway and mobile layer, and the cloud services layer. The sensor layer consists of all sensors provided by or compatible with the [Company] platform. The gateway and mobile layer consists of gateways and the mobile application. The cloud layer consists of [Company] cloud resources as well as additional analytics and development environments.

Responsibilities

Access control for the sensor layer and the gateway and mobile layer is transferred to customers. The only exception is debugging and troubleshooting performed on-premises by [Company] employees with the customer's assistance. Online gateways can be accessed through remote sessions using a cloud layer component, the Access Controller. [Company] is responsible for the secure design and implementation of the technical access control mechanisms for these layers.

The cloud layer consists of customer-facing services ([Company] Users portal and REST API), vendor-facing services ([Company] Vendor portal and REST API) and administrative and maintenance services ([Company] Admin portal, REST API and cloud infrastructure portal). Customers are responsible for granting access to customer-facing services within the scope of their plants and assets. [Company] is responsible for the secure design, implementation and maintenance of the access mechanisms for those services. [Company] is fully responsible for access to administrative and maintenance services, except the cloud infrastructure portal, where a shared responsibility model applies with [Parent Company] and the Cloud Service Provider.

Access to analytics and development components is a shared responsibility with [Parent Company], which manages the identities and access of [Parent Company] subsidiaries, including [Company] and

[Parent Company] Regional. For cloud infrastructure and Software-as-a-Service platforms, the shared responsibility model with the Cloud Service Provider applies.

Access control for physical facilities rests with the owner of the facility. [Company] is responsible for access to facilities it owns; for rented facilities, a shared responsibility model applies based on service level agreements.

Customers of [Company] are fully responsible for physical access control at their facilities.

Access Control Principles

[Company] follows the Zero Trust security model, and the following principles therefore apply:

- Verify Explicitly – Always authenticate and authorize based on all available data points, including identity, location, device health, service or workload, data classification and anomalies.
- Least Privilege Access – Users receive only the minimum access necessary for their job functions, limited with Just-In-Time and Just-Enough-Access (JIT/JEA), risk-based adaptive policies and data protection, with proper role segmentation. Entra PIM should be used.
- Assume Breach – Minimize the blast radius and segment access, verify end-to-end encryption (at rest and in transit), and use analytics to gain visibility, detect threats and improve defenses. SIEM monitoring should be used.
- Need-to-Know – Access to information is granted only when the user needs it to perform their job.
- Role-Based Access Control – Access permissions should be assigned based on the user's role within the organization. Microsoft Entra and Azure RBAC roles should be used.

Authentication

Authentication is a method to ensure that a subject (an entity that requests access) is who they claim to be. This process is crucial in access control and is typically performed before authorization.

Physical facilities

Every [Company] and [Parent Company] employee should authenticate digitally using their assigned individual badge. Additionally, every employee may be identified by an official national ID document. Authentication with a national ID document requires at least line manager approval.

Facilities should have adequate mechanisms implemented to allow employees to authenticate with their digital identity badge.

Sharing or impersonation of individually assigned documents is strictly prohibited by this policy. Regional regulations apply in each country where physical facilities are located.

Acceptable national ID documents are:

- passports,
- identity cards,
- driving licenses,
- social security cards (USA).

Authentication at customer physical facilities is outside the scope of this policy.

Cloud administrative, development and analytics services

Authentication: [Company] should use modern authentication protocols (OIDC, SAMLv2) for all its services, including cloud administrative, development, analytics, and resource access services. This authentication should be based on Corporate Identity Provider Services (IdP services) managed by IT Services departments, which include the [Parent Company] IT Department and the [Parent Company] Regional IT Department. Each entity should always use its own identity (or an identity assigned to it) to perform authentication to any other services, devices or entities.

Identity delegation/Impersonation: The delegation of identity or impersonation is not allowed under this policy. Sharing or exposure of credentials (API Keys, Secrets, Passwords) is strictly prohibited. The only way to obtain new credentials is to generate new ones, which helps prevent potential breaches and compromise of identities.

Digital Identity: Each person/employee may have a maximum of one digital identity in each IdP service. This helps ensure non-repudiation and reduces the attack surface. It is recommended to have only one identity in the origin IdP while being a guest in other IdPs to have the required access granted.

Device Identity: Each device should have a maximum of one unique digital identity.

Cloud Service Identity: Each cloud service (resource) should have its own unique identity registered in IdP (App Registration/Service Principals) when access for other services is required. A service may have more than one identity, depending on the authorization needed to perform the required actions.

Azure Resources: Azure-based resources should use System Assigned or User Assigned Managed Identities for authentication to access other cloud-based services. User Assigned Identities must be documented and should be used by only one resource.

Customer and Vendor provided services

Authentication: [Company] should deliver modern authentication protocols (OIDC, SAMLv2) for customer services. This authentication should be based on Customer oriented Identity Provider Services (B2C IdP services) managed by a dedicated [Company] team. Each entity should always use its own identity (or an identity assigned to it) to perform authentication to any other services, devices or entities. Password policies and proper security protection mechanisms shall be implemented.

Identity delegation/Impersonation: The delegation of identity or impersonation is not allowed under this policy. Sharing or exposure of credentials (API Keys, Secrets, Passwords) is strictly prohibited. The only way to obtain new credentials is to generate new ones, which helps prevent potential breaches and compromise of identities.

Digital Identity: Each person may have a maximum of one digital identity in each IdP service. This helps ensure non-repudiation and reduces the attack surface. It is recommended to have only one identity in the origin IdP while being federated (SAML, OIDC) in provided services.

Device Identity: Each device (Gateway, Sensors) should have a maximum of one unique digital identity. Appropriate cryptography should be used to deliver identity claims.

Device Authentication: Authentication on customer-delivered devices depends on the device vendor and model. Authentication mechanisms should meet minimal security requirements. [Company] is

responsible for technical evaluation and implementation of proper mechanisms. The customer is responsible for the proper configuration of such mechanisms.

Emergency Access ("Break Glass") Accounts

To ensure administrative continuity during catastrophic Identity Provider failures (e.g., MFA service outage, federation failure, or accidental lockout), the Platform shall maintain two (2) Emergency Access Accounts.

Account Configuration

Cloud-Only Identity: These accounts must be created directly in the cloud directory (e.g., *.onmicrosoft.com) and must not be synchronized from on-premises directories or federated identity providers.

Role Assignment: These accounts must hold the Global Administrator role permanently to ensure full recovery capabilities.

Policy Exclusion: To prevent lockout during policy misconfiguration or service failure, these accounts must be explicitly excluded from:

All Conditional Access policies.

Standard Multi-Factor Authentication (MFA) enforcement.

Credential Management

Complexity: Passwords must be randomly generated and meet the maximum complexity length supported (e.g., 25+ characters).

Storage: Credentials must be stored securely and offline (e.g., in a physical safe or an air-gapped password vault) to prevent digital theft.

Redundancy: The credentials for the two accounts should be stored in separate locations to ensure availability if one location is inaccessible.

Monitoring and Usage

Prohibited Use: These accounts are strictly prohibited from use in daily operations.

Alerting: A specific monitoring rule must be configured so that any authentication attempt or sign-in by an Emergency Access Account triggers an immediate High-Priority Security Alert to the entire Security Team.

Validation: The Emergency Access process (including credential retrieval and login) must be tested at least every 90 days to ensure the accounts are functional.

Authorization

Authorization is the process that comes after authentication. It involves granting or denying access to specific resources or permissions based on the authenticated user’s privileges.

Physical facilities

Every [Company] and [Parent Company] employee is authorized to access permitted facilities based on their digital identity badge or a national ID document.

Cloud administrative, development and analytics services

The least privilege principle applies to authorization for administrative, development and analytics services. Access to such services is based on role-based access control (OAuth2 or another service-oriented protocol) and is derived from group membership. Authorization is evaluated on the service side.

The [Company] Security Team, in cooperation with Management and the IT service provider (if applicable), is responsible for monitoring and maintaining proper access to services managed by the [Company] team.

The [Parent Company] IT service provider is fully responsible for maintaining access to corporate tenant accounts and corporate tenant services that are not managed by the [Company] team (Microsoft SaaS, Entra groups).

Customer and Vendor provided services

Customers and vendors are fully responsible for granting access to their resources in accordance with the principle of least privilege. Access is granted based on the role assigned to the user. Authorization is based on OAuth2 and is validated on the service side.

[Company] is responsible for providing the technical solution and capabilities (OAuth2, roles matrix), as well as security testing of them to prevent privilege escalation and access control errors. [Company] cannot manage customer roles without a clear request from the customer (troubleshooting, support operations).

[Company] may manage vendor access depending on business requirements.

Policy Compliance

Measurement

The [Company] Management Review Team in cooperation with [Parent Company] representatives will verify compliance with this policy through various methods, including but not limited to business tool reports, internal and external audits, and feedback to the policy owner.

Appropriate monitoring and analytics tools should be implemented to provide observability for incident response and to detect drift from this policy.

Exceptions

Any exception to the policy must be approved and documented by the Information Security Specialist in advance and reported to [Company] Management Review Team.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action up to and including termination of employment and further legal action.